

CLOUD SECURITY RISK ASSESSMENT

Governance, Risk and Compliance

Single Azure-hosted virtual machine · GRC-Windows-VM01

Field	Detail
Assessment subject	Azure virtual machine GRC-Windows-VM01
Resource group	GRC-Lab (Central India, Zone 1)
Assessment type	Configuration review — non-exploitative
Frameworks applied	NIST Cybersecurity Framework 1.1; CIS Controls v8
Prepared by	Tanmay Sarkar
Report date	August 2026
Classification	Lab exercise — no production data in scope
Overall risk posture	HIGH

This report documents the results of a cloud security risk assessment conducted on a single Azure-hosted virtual machine from a Governance, Risk and Compliance perspective. No exploitation, credential attack or penetration testing was performed at any stage.

Contents

- 1. Executive Summary.....3
 - Principal finding.....3
 - Summary of findings.....3
- 2. Scope and Environment.....5
- 3. Asset Identification.....6
- 4. Threat and Vulnerability Summary.....7
- 5. Risk Assessment Methodology.....8
- 6. Risk Register.....9
 - Scoring justifications.....9
- 7. Security Controls and Compliance Mapping..... 11
- 8. Recommended Mitigation Actions..... 12
- 9. Known Limitations..... 12
- 10. Overall Risk Posture..... 13

1. Executive Summary

This assessment evaluated a single Windows virtual machine hosted in Microsoft Azure, examining its configuration, identity model, network exposure and monitoring coverage in order to identify assets, characterise realistic threats, quantify risk and recommend controls aligned to recognised frameworks.

Nine risks were identified. Two are rated Critical, two High, four Medium and one Low. The overall risk posture of the assessed environment is HIGH. The environment is small, but the combination of an internet-reachable administrative entry point, single-factor authentication and no detection capability means a single credential guess would produce complete, unobserved compromise of the host.

Principal finding

Remote Desktop Protocol (TCP/3389) is permitted inbound from any source address on the internet. This is not a theoretical exposure. Within hours of deployment, the virtual machine's own Windows Security log had recorded repeated Event ID 4625 failed-logon entries carrying a NULL SID, arriving at intervals of 93 to 96 seconds — a regularity inconsistent with human activity and characteristic of automated authentication attempts against an exposed service.

The machine had no DNS name, hosted no application and had existed for a matter of hours. It was found regardless. Internet-facing RDP does not wait to be discovered.

Evidential caveat

The Source Network Address field within each Event 4625 record was not captured during the assessment. Without it these attempts cannot be attributed to an external origin with certainty; a misconfigured local client could in principle produce a comparable pattern.

This report therefore records the activity as consistent with automated authentication attempts rather than as a confirmed attack. Collecting those source addresses is the first recommendation under Section 9.

Summary of findings

Rating	Risk	Principal weakness	Score	Priority
Critical	RDP open to the internet	NSG allows TCP/3389 from Source: Any	20	P1
Critical	Single admin, no MFA	Password-only authentication	20	P1
High	Unmanaged OS patching	No baseline; no update schedule	12	P2
High	No centralised logging	No workspace; no alert rules	12	P1
Medium	Standing privileged access	No RBAC separation; no PIM	10	P2
Medium	No network segmentation	NSG bound to NIC only	8	P3
Medium	Unrestricted egress	AllowInternetOutBound in force	8	P3
Medium	No recovery point	Backup not configured	8	P2
Low	Encryption / integrity gaps	Integrity monitoring disabled	3	P4

Four actions resolve both Critical risks and one of the High risks: restrict the NSG source address, place RDP behind Azure Bastion or Just-in-Time access, require multi-factor authentication for administrative access, and forward Security event logs to a Log Analytics workspace with an alert rule on failed-logon volume. The first of these is a single field change.

2. Scope and Environment

2.1 Assessment scope

- A single Azure virtual machine and the resources Azure created alongside it
- The local identity store on that machine and the subscription control plane surrounding it
- No other Azure services, applications or workloads
- Assessment performed from a GRC perspective: configuration review and native logging only, with no exploitation

2.2 Environment details

Item	Observed value
Cloud provider	Microsoft Azure
Subscription	Azure for Students Starter (identifier redacted)
Resource group	GRC-Lab
Region	Central India (Zone 1)
Virtual machine	GRC-Windows-VM01 (computer name GRC-Windows-VM0)
Operating system	Windows 11 Pro, version 25H2, x64 Gen 2 (image win11-25h2-pro)
Size	Standard B2als_v2 — 2 vCPU, 4 GiB RAM
OS disk	Standard SSD, managed; 0 data disks
Virtual network	GRC-Windows-VM01-vnet / subnet "default"
Private IP	10.1.0.4
Public IP	IPv4 enabled on the NIC (address redacted); no DNS name configured
Network security group	GRC-Windows-VM01-nsg — attached to the network interface only
Access method	Remote Desktop Protocol, TCP/3389
Administrative account	azureadmin — local, sole member of Administrators
Security type	Trusted Launch — Secure Boot enabled, vTPM enabled, integrity monitoring disabled
VM agent	Ready (version 2.7.41491.1216); no extensions installed

2.3 Baseline assumption

The virtual machine is assumed to run a standard Windows 11 Pro installation with no security measures beyond those Azure and the operating system apply by default. No custom Group Policy, CIS Benchmark or organisational security standard has been applied. Windows Defender and Windows Firewall are enabled at their default settings, and no additional host-based security tooling is installed.

3. Asset Identification

Assets extend well beyond hardware. Anything that holds value, grants access or confers privilege belongs in the inventory — accounts, network paths and cloud permissions among them. Nine assets were catalogued.

ID	Category	Asset	Observed configuration	Why it matters
A-01	Compute	Azure VM GRC-Windows-VM01	Windows 11 Pro 25H2; B2als_v2; Trusted Launch	Hosts the OS and every service in scope
A-02	Identity	Local admin account azureadmin	Only enabled account; sole Administrators member	Complete and unrestricted access to the host
A-03	Network	Public IP on the VM NIC	Public IPv4 enabled; private 10.1.0.4; no DNS name	Turns a local weakness into a remote one
A-04	Network	RDP service, TCP/3389	NSG rule 300: TCP/3389, Source Any, Allow	The single authenticated entry path into the host
A-05	Network	NSG GRC-Windows-VM01-nsg	NIC-attached only; impacts 0 subnets	The only network access control in the estate
A-06	Cloud control	Subscription and GRC-Lab group	Azure for Students Starter; no resource locks	Outranks every control inside the guest OS
A-07	Data	OS disk (managed, Standard SSD)	Encryption at host disabled; platform SSE applies	Holds the OS and credential material
A-08	Logging	Windows Security event log	1,414 events; local retention only; no alerting	The only record of who authenticated and when
A-09	Monitoring	Azure platform metrics	Platform metrics only; detailed metrics absent	Partial coverage creates false assurance

Two entries deserve emphasis. The RDP service is not merely a port; it is the only authenticated path into the host and therefore the whole of the remotely reachable attack surface. The subscription control plane outranks every control inside the guest operating system — an attacker with control-plane access can snapshot the disk or execute code through a VM extension without ever authenticating to Windows.

4. Threat and Vulnerability Summary

This section links what could go wrong (threats) with why it could succeed (vulnerabilities). A vulnerability is a weakness rather than an attack; no proof of exploitation is required for a configuration to be documented as one.

Asset	Threat	Vulnerability	Observed evidence
RDP endpoint (TCP/3389)	Automated brute-force from the internet	NSG allows TCP/3389 from Source: Any	Repeated Event 4625 failures, NULL SID, ~95 s apart
azureadmin administrator	Credential compromise	Password-only auth; no MFA; predictable name	Get-LocalUser; Administrators group has one member
Windows 11 Pro guest OS	Exploitation of a known CVE	Default config; no baseline; unmanaged patching	No VM extensions; no update management configured
Security event log	Activity goes unnoticed; evidence lost	Local-only logs; no workspace, no alert rules	Monitor shows platform metrics only
Subscription / resource group	Unauthorized config change or deletion	Standing privilege on one identity; no PIM or locks	Single operator identity across all resources
VNet and subnet	Lateral movement post-compromise	NSG on NIC only; no subnet NSG or ASGs	"Impacts 0 subnets, 1 network interface"
Outbound network path	C2 channel or data exfiltration	AllowInternetOutBound permits all egress	Outbound rule 65001: Any → Internet, Allow
VM availability	Destructive event, no recovery point	No Azure Backup, vault, snapshot or lock	Backup + disaster recovery not configured
OS disk and boot chain	Offline disk access or boot tampering	Encryption at host off; integrity monitoring off	Secure Boot on, vTPM on, integrity monitoring off

5. Risk Assessment Methodology

Risks were scored using a standard Likelihood × Impact model so that findings can be compared consistently across differing assets and threat types, and so that each score can be defended in review.

5.1 Scoring scales

Likelihood	Definition	Impact	Definition
1	Rare	1	Minimal
2	Unlikely	2	Minor
3	Possible	3	Moderate
4	Likely	4	High
5	Almost certain	5	Critical

5.2 Rating bands

1 – 5	6 – 10	11 – 15	16 – 25
Low	Medium	High	Critical

5.3 How the scores were reached

Likelihood was assessed against four questions: is the asset reachable from the internet; how prevalent is the technique in the wild; how much skill does exploitation require, or can it be automated; and what preventive or detective controls already stand in the way.

Impact was assessed against the consequence of successful exploitation: loss of confidentiality, integrity or availability; the level of access gained, user against administrator; operational disruption; and any compliance or reputational consequence. Impact scores rise where the affected asset carries elevated privilege or broad access.

On proportionate scoring

One finding in this register (R-09) is rated Low and explicitly accepted rather than escalated. A register in which every finding is Critical directs attention nowhere and tends not to be acted upon. The discipline of a risk assessment lies in scoring proportionately and being able to defend each number — including the low ones.

6. Risk Register

ID	Asset	Threat	L	I	Score	Rating
R-01	RDP endpoint (TCP/3389)	Automated brute-force / password spray	5	4	20	Critical
R-02	azureadmin local administrator	Credential compromise → full system control	4	5	20	Critical
R-03	Windows 11 Pro guest OS	Exploitation of unpatched vulnerabilities	3	4	12	High
R-04	Windows Security event log	Undetected intrusion; loss of evidence	4	3	12	High
R-05	Subscription / resource group	Privilege misuse on the management plane	2	5	10	Medium
R-06	VNet segmentation	Lateral movement after compromise	2	4	8	Medium
R-07	Outbound network path	C2 beaconing / data exfiltration	2	4	8	Medium
R-08	VM availability	Destructive event with no recovery point	2	4	8	Medium
R-09	OS disk & boot integrity	Offline disk access / boot tampering	1	3	3	Low

Risk profile: 2 Critical • 2 High • 4 Medium • 1 Low

6.1 Scoring justifications

Justification is what makes a register auditable. Scores must be supported rather than assumed.

Risk	Justification
R-01	Likelihood 5. Exposure is measured, not assumed: the Security log recorded repeated Event ID 4625 failures with a NULL SID at ~95-second intervals within hours of deployment. Impact 4 — successful authentication yields an interactive host session, not control-plane access.
R-02	Likelihood 4. The account name is predictable, the endpoint is internet-reachable, and no MFA or lockout control was observed. Impact 5 — Administrators hold complete and unrestricted access, so compromise is total loss of C, I and A for the asset.
R-03	Likelihood 3. Exploitation requires a specific unpatched CVE rather than a guessed password, but an unmanaged patch cadence leaves exposure windows open-ended. Impact 4 — most privilege-escalation chains on this host end at SYSTEM.
R-04	Likelihood 4. Malicious activity is already present in the log and nothing is configured to surface it to a human. Impact 3 — absence of detection causes no loss directly, but extends dwell time and destroys evidence when the host is rebuilt or the log rolls.
R-05	Likelihood 2. The management plane is guarded by the identity provider rather than an exposed port, and the lab has one trusted operator. Impact 5 — control-plane compromise permits snapshot exfiltration, extension-based code execution, and deletion across the subscription.
R-06	Likelihood 2. A single workload means there is little to move laterally toward today. Impact 4 — NIC-only enforcement removes a defence-in-depth layer that would contain an intrusion once the estate grows.

Risk	Justification
R-07	Likelihood 2. Realised only after a successful initial compromise. Impact 4 — unrestricted egress lets an attacker establish C2 and move data out without encountering a single control.
R-08	Likelihood 2 in a lab holding no production data. Impact 4 — with no recovery point the only response to a destructive event is a full rebuild, and all host state is permanently lost.
R-09	Likelihood 1. Azure managed disks are already encrypted at rest with platform-managed keys, and Secure Boot with vTPM is active. Impact 3 — the residual gap is customer key ownership and lost attestation alerting, not plaintext data. Retained as an accepted risk for lab scope.

7. Security Controls and Compliance Mapping

Each identified risk was matched to a control and then mapped to recognised frameworks, so that every recommendation can be justified, audited and traced back to an established standard rather than to preference or tooling. Controls are categorised as preventive (stop it), detective (notice it) or corrective (recover from it). What matters for the mapping is whether the control satisfies the framework's intent, not which product implements it.

Risk	Recommended control	Type	NIST CSF 1.1	CIS v8
R-01	Restrict NSG source to a trusted CIDR; move to Azure Bastion or Just-in-Time VM access	Preventive	PR.AC-3; PR.PT-4	4.6; 12.7
R-02	MFA for administrative access; named admin account; account lockout policy	Preventive	PR.AC-1; PR.AC-7	5.4; 6.5
R-03	Azure Update Manager schedule; security baseline via Azure Policy guest configuration	Corrective	PR.IP-1; PR.IP-12	4.1; 7.3
R-04	Log Analytics workspace; Defender for Servers; alert rule on Event 4625 volume	Detective	DE.CM-1; DE.AE-3	8.9; 13.1
R-05	Least-privilege RBAC; Entra PIM just-in-time elevation; resource locks	Preventive	PR.AC-4; ID.GV-2	5.1; 6.8
R-06	Subnet-level NSG in addition to the NIC; Application Security Groups	Preventive	PR.AC-5	12.2; 4.4
R-07	Egress filtering via Azure Firewall; enable NSG flow logs	Preventive / Detective	PR.PT-4	13.6; 12.2
R-08	Azure Backup with Recovery Services vault; vault soft delete; delete lock	Corrective	PR.IP-4; RC.RP-1	11.2; 11.3
R-09	Enable encryption at host; enable Trusted Launch integrity monitoring	Preventive / Detective	PR.DS-1	3.11; 4.1

Framework identifiers follow NIST Cybersecurity Framework 1.1, matching the assessment brief. Under CSF 2.0 the PR.AC category has been reorganised into PR.AA (Identity Management, Authentication and Access Control), and much of PR.IP now falls under PR.PS (Platform Security). CIS references are to Controls v8 safeguards.

8. Recommended Mitigation Actions

Actions are ordered by the risk they retire rather than by ease of implementation, though in this case the highest-value action is also the smallest.

Priority 1 — immediate

1. Change the NSG rule "RDP" (priority 300) source from Any to a specific trusted IP address or CIDR range. One field; it removes the exposure driving both Critical risks.
2. Deploy Azure Bastion, or enable Microsoft Defender for Cloud Just-in-Time VM access, so that TCP/3389 is not permanently open to any network.
3. Require multi-factor authentication for administrative access — through Entra ID join with Conditional Access, or Bastion with Entra login — and create a named administrative account in place of the default azureadmin.
4. Create a Log Analytics workspace, route the VM's diagnostic and Security event logs to it, and configure an alert rule on Event ID 4625 volume so that failed-logon bursts reach a human.

Priority 2 — within 30 days

1. Enrol the VM in Azure Update Manager with a recurring maintenance window, and apply the Microsoft or CIS security baseline through Azure Policy guest configuration.
2. Replace standing privileged access with Entra Privileged Identity Management just-in-time elevation, and apply a CanNotDelete lock to the GRC-Lab resource group.
3. Configure Azure Backup with a Recovery Services vault, a daily policy and vault soft delete enabled.

Priority 3 — within 90 days

4. Attach a network security group at subnet level in addition to the network interface, and express workload intent through Application Security Groups.
5. Constrain outbound traffic through NSG destination rules or Azure Firewall FQDN filtering, and enable NSG flow logs with traffic analytics.

Priority 4 — accepted

6. Enable encryption at host and Trusted Launch integrity monitoring when the environment moves beyond lab scope. Retained as an accepted risk in the interim (R-09).

9. Known Limitations

Stating the boundaries of an assessment is part of the deliverable, not a qualification of it. A reader needs to know what the findings do not cover.

- Source addresses for the Event 4625 records were not captured. The failed logons are consistent with automated attempts but are not confirmed as external in origin. Collecting the Source Network Address field is the single most valuable addition to a repeat assessment.
- This is a point-in-time review. Configuration was assessed across one session; no configuration-drift monitoring or continuous compliance scanning was in place.
- No exploitation was performed, by design. Vulnerability presence is inferred from configuration and vendor documentation rather than demonstrated through proof of exploitability.
- Scope covers a single workload. Segmentation and lateral-movement risk (R-06) is therefore assessed against a hypothetical future estate rather than an observed one.
- No data classification was performed. Impact scores assume the host holds no regulated or production data; any real workload would require these scores to be revisited against actual data sensitivity.

10. Overall Risk Posture

Overall risk posture: HIGH

The assessed environment is small, but size does not reduce exposure. An internet-reachable administrative entry point, protected by a single factor, on a host with no detective capability, is the configuration that produces the majority of cloud intrusions in practice. Observed authentication attempts within hours of deployment confirm the exposure is live rather than latent. Retiring the two Critical risks requires four actions, one of which is a single field change; addressing the two High risks brings the environment to a posture appropriate for its purpose.

Report ends.